Informe de Seguridad Web

Remote Code Execution via Web Shell Upload

Plataforma: PortSwigger Web Security Academy
Categoría: File Upload Vulnerabilities
Herramienta: Burp Suite
Resultado: Laboratorio resuelto

---

1. Título

Ejecución remota de código mediante subida de archivos (File Upload RCE).

2. Descripción

Durante la evaluación del laboratorio de PortSwigger Web Security Academy, se identificó una vulnerabilidad en la funcionalidad de subida de avatares de la aplicación.

La aplicación permitió cargar un archivo PHP mediante una petición HTTP `POST` dirigida al endpoint `/my-account/avatar`. El servidor aceptó el archivo y lo almacenó en la ruta `avatars/avatar.php`.

Al acceder al archivo desde el navegador, se comprobó que el servidor interpretaba y ejecutaba el código PHP proporcionado. Posteriormente, se utilizó esta capacidad para leer un archivo sensible del sistema, ubicado en `/home/carlos/secret`, y completar el objetivo del laboratorio.

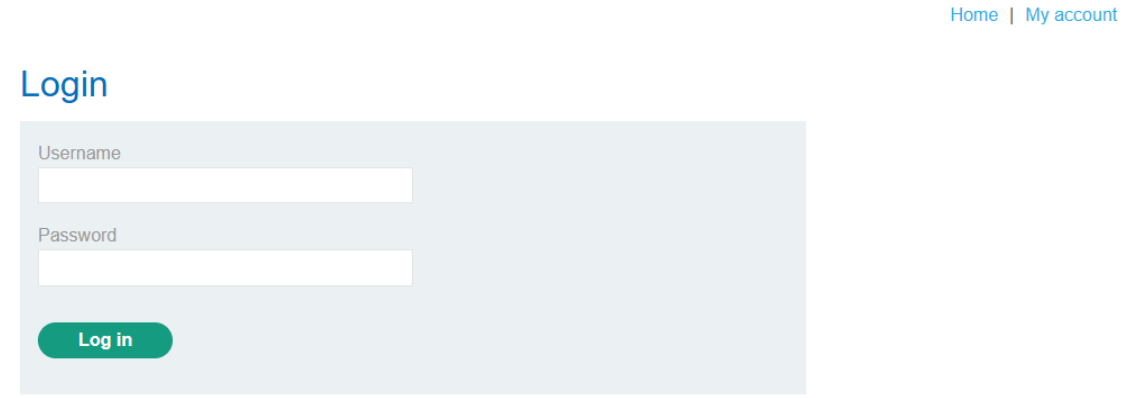
3. Metodología

1. Se accedió al laboratorio y se identificó la funcionalidad de subida de avatares.
2. Se interceptó y analizó la petición HTTP de subida utilizando Burp Suite.
3. Se cargó una imagen PNG legítima para establecer el comportamiento inicial de la funcionalidad.
4. Se modificó la petición para subir un archivo con extensión `.php`.
5. Se verificó que el servidor aceptó el archivo y confirmó su almacenamiento en `avatars/avatar.php`.
6. Se accedió al archivo subido y se comprobó la ejecución de código PHP mediante la salida observada en el navegador.
7. Se modificó el código ejecutado para leer el archivo objetivo del laboratorio.
8. Se obtuvo el contenido solicitado y se envió el secreto mediante el mecanismo de validación del laboratorio.
9. Se verificó que el laboratorio mostrara el estado `Solved`.

4. Evidencia

Evidencia 01 — Página inicial del laboratorio

Archivo:

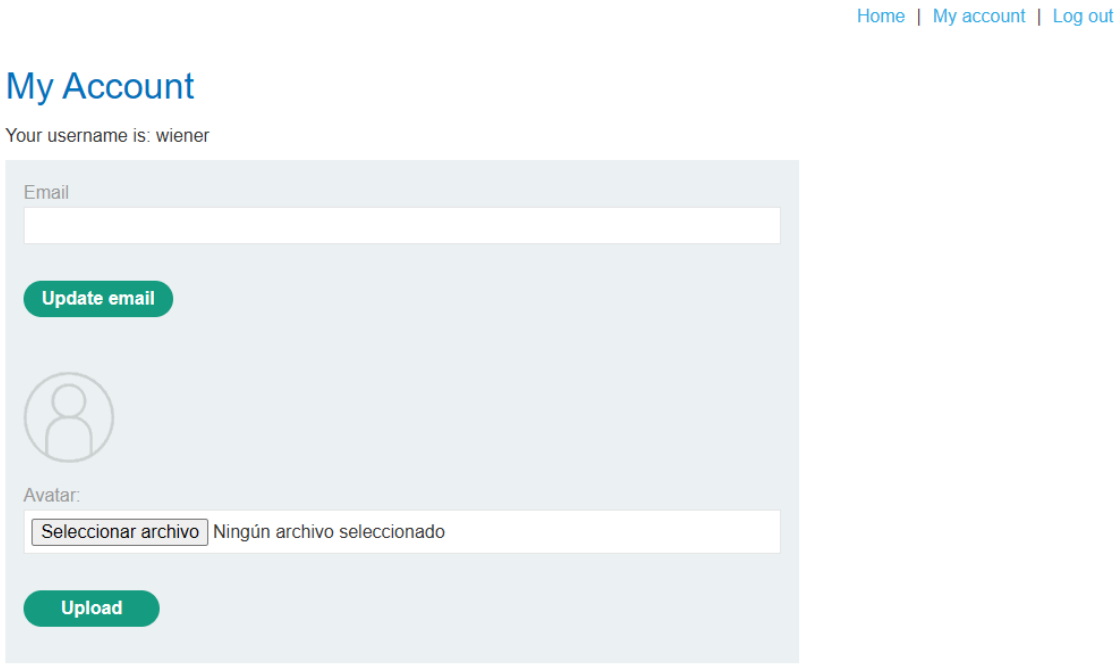


Captura de la página inicial del laboratorio de PortSwigger Web Security Academy.

Objetivo: documentar el entorno utilizado para la prueba.

Evidencia 02 — Funcionalidad de subida de archivos

Archivo:



Captura de la funcionalidad de subida de avatares disponible en la sección de cuenta del usuario.

Objetivo: identificar el punto de entrada evaluado.

Evidencia 03 — Petición original de subida

Archivo:

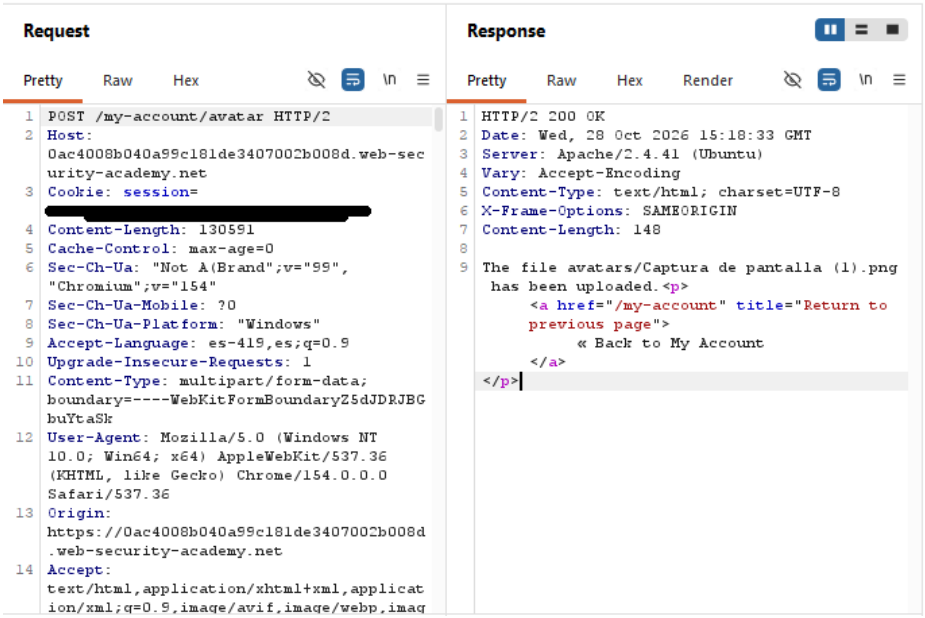


Petición HTTP `POST /my-account/avatar` capturada mediante Burp Suite, correspondiente a la subida de una imagen PNG legítima.

Objetivo: documentar el comportamiento inicial de la funcionalidad.

Evidencia 04 — Respuesta del servidor

Archivo:

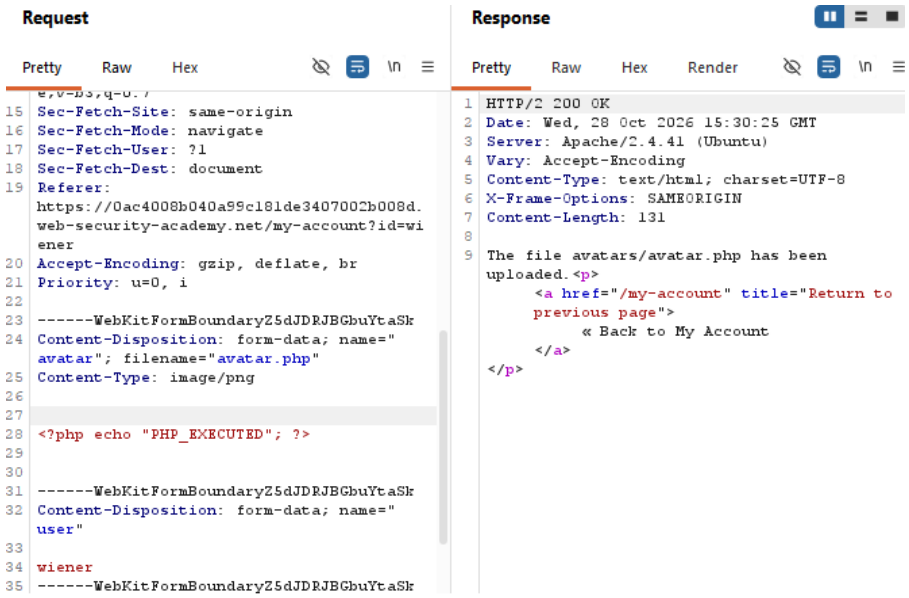


Respuesta HTTP que confirma que el archivo original fue aceptado y almacenado en la ubicación de avatares.

Objetivo: registrar la respuesta inicial del servidor ante una subida válida.

Evidencia 05 — Subida de archivo PHP

Archivo:



Petición modificada en Burp Repeater para cargar un archivo denominado `avatar.php`, cuyo contenido se reemplazó por código PHP de prueba.

Objetivo: documentar la modificación de la petición y la carga del archivo ejecutable.

Evidencia 06 — Ejecución de código PHP

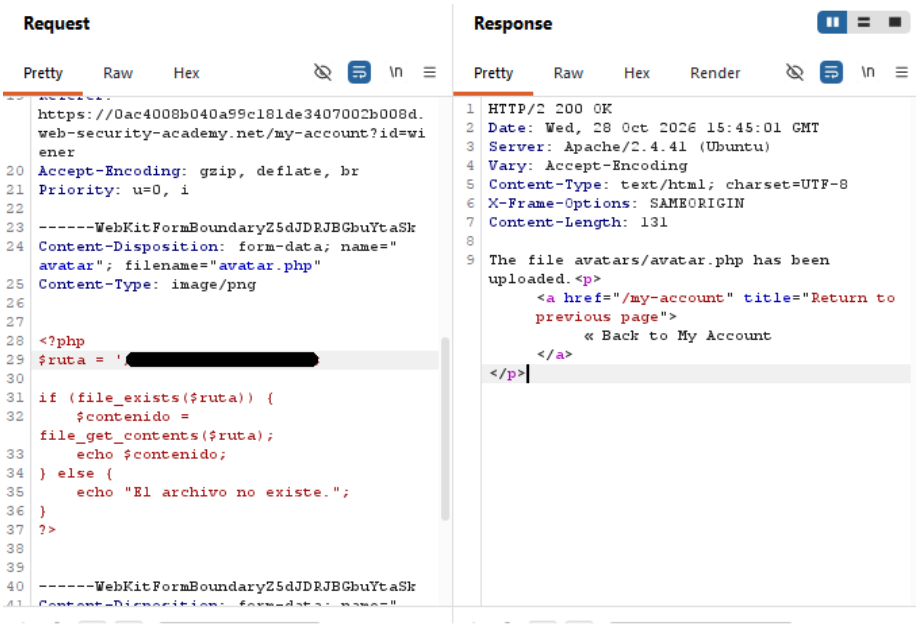
Archivo:

Salida del navegador que muestra el texto `PHP_EXECUTED`, confirmando que el servidor interpretó y ejecutó el código PHP incluido en el archivo subido.

Objetivo: demostrar la ejecución de código del lado del servidor.

Evidencia 07 — Web shell utilizada para leer el archivo

Archivo:



Captura de la petición modificada en Burp Repeater, con el código PHP utilizado para intentar leer el archivo objetivo del laboratorio.

Objetivo: documentar el paso de ejecución de código a acceso al archivo sensible.

Evidencia 08 — Resultado de la lectura del archivo

Archivo:

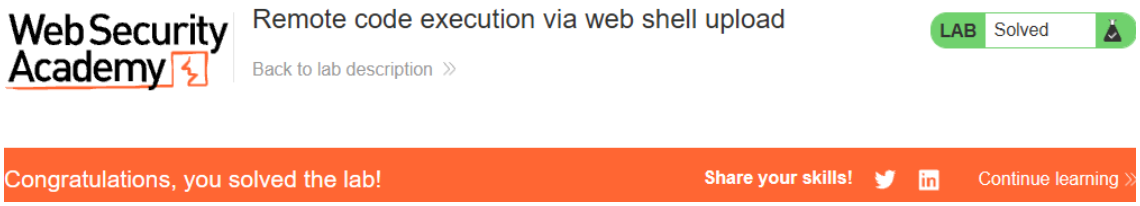


Captura del navegador que muestra parte de la salida obtenida al leer el archivo `/home/carlos/secret`. El valor sensible se encuentra censurado para evitar su divulgación.

Objetivo: demostrar el acceso al contenido del archivo sin exponer el secreto.

Evidencia 09 — Laboratorio resuelto

Archivo:



Captura del estado final `Solved` mostrado por PortSwigger Web Security Academy después de enviar el secreto solicitado.

Objetivo: confirmar la finalización satisfactoria del laboratorio.

[Insertar captura 09 aquí]

5. Impacto

Confidencialidad (C): Alta. La ejecución de código permitió acceder al contenido de un archivo sensible del sistema de archivos del servidor.

Integridad (I): Alta potencial. La ejecución de código podría permitir modificar archivos o recursos accesibles para el proceso web, según sus permisos.

Disponibilidad (A): Alta potencial. Un atacante podría afectar el funcionamiento de la aplicación o los recursos disponibles para el proceso web, dependiendo de sus privilegios y de las restricciones del entorno.

El impacto efectivo depende de los permisos del proceso web, la configuración del servidor y las medidas de aislamiento implementadas.

6. Causa raíz

La aplicación permitió que un archivo PHP proporcionado por el usuario fuera almacenado en una ubicación accesible desde el navegador y que el servidor lo interpretara como código ejecutable.

La causa raíz es la falta de controles adecuados sobre los archivos subidos y la ausencia de una separación efectiva entre el almacenamiento de contenido proporcionado por el usuario y la ejecución de código del lado del servidor.

La extensión y el tipo MIME declarados por el cliente no deben considerarse mecanismos suficientes de validación.

7. Remediación

- Implementar una lista permitida de formatos de archivo compatibles con la funcionalidad, validando también el contenido real del archivo.
- Rechazar archivos ejecutables y contenido que no corresponda al formato esperado.

- Almacenar los archivos subidos fuera del directorio público de la aplicación cuando sea posible.
- Si los archivos deben ser accesibles públicamente, configurar el servidor para impedir la ejecución de scripts en ese directorio.
- Generar nombres de archivo aleatorios en el servidor y no confiar directamente en el nombre proporcionado por el usuario.
- Aplicar el principio de mínimo privilegio al proceso web.
- Restringir el acceso del proceso web a archivos sensibles del sistema.
- Registrar las operaciones de subida y establecer controles de supervisión para detectar comportamientos anómalos.

8. CVSS aproximado

Puntuación propuesta: 8.8 — Alta (CVSS v3.1).

Vector propuesto:

```
CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
```

Esta puntuación es una estimación para un escenario de ejecución remota de código por parte de un usuario autenticado con privilegios bajos, con impacto alto sobre confidencialidad, integridad y disponibilidad.

La puntuación debe interpretarse como orientativa y ajustarse a las condiciones reales de explotación y al impacto demostrado. No constituye una puntuación oficial publicada por PortSwigger para el laboratorio.

9. Prioridad

Alta.

La posibilidad de ejecutar código PHP a través de la funcionalidad de subida de archivos requiere una corrección prioritaria. Según los permisos del proceso web, esta vulnerabilidad puede permitir el acceso a información sensible y la ejecución de operaciones no autorizadas en el servidor.

10. Referencia

PortSwigger Web Security Academy — File upload vulnerabilities: Remote code execution via web shell upload.

https://portswigger.net/web-security/file-upload/lab-file-upload-remote-code-execution-via-web-shell-upload